



PHP filters 30m

Earlier in this topic we introduced filters. The PHP filter is used to validate and sanitize external inputs. It plays an important role in the security of a web application, especially when data originates from unknown and unsecure sources. As you saw before, filters can be used to sanitize and validate data inputted in HTML forms and from other external sources.

There are two main types of filters, which are listed below:

1. **Validation:** is used to validate or check if the data meets certain qualifications or not. For example, `FILTER_VALIDATE_URL` will determine if the data is a valid URL, but it will not change the existing data by itself.
2. **Sanitisation:** unlike validation, sanitisation will sanitise data to ensure that no undesired characters are used by removing or altering the data. For example, `FILTER_SANITIZE_EMAIL` will remove all the characters that are inappropriate for an email address to contain, other than the @ symbol. That said, it does not validate the data.

Why use filters?

Many web applications receive external input such as:

- user input from a form
- cookies
- web services data
- server variables
- database query results.

[Skip to main content](#)

The filter function is used to validate and filter data that comes from an unknown source. There are several types of filter functions that each perform different tasks. Some important filter functions are listed in the table below.

Function	Description
<code>filter_var()</code>	Filters a specific variable
<code>filter_var_array()</code>	Filters multiple variables (an array of variables)
<code>filter_has_var()</code>	Checks if the variable of a specific input type exists or not
<code>filter_id()</code>	Helps to get the filter id of the specified filter name
<code>filter_list()</code>	Returns a list of supported filter names in the form of an array
<code>filter_input()</code>	Gets an external variable and filters it if set to do so
<code>filter_input_array()</code>	Same as <code>filter_input()</code> but gets multiple variables (an array of variables) and filters them if set to do so

We will focus on the filter function `filter_var()` in this topic because it is used often.

When using a filter function, you'll also use a predefined filter constant. There are many predefined validate filter constants. The most common ones are listed in the table below.

Filter	Description
<code>FILTER_VALIDATE_BOOLEAN</code>	Checks for a valid Boolean value
<code>FILTER_VALIDATE_EMAIL</code>	Checks for a valid email address
<code>FILTER_VALIDATE_FLOAT</code>	Checks for a valid float value
<code>FILTER_VALIDATE_INT</code>	Checks for a valid integer value
<code>FILTER_VALIDATE_IP</code>	Checks for a valid IP address value

[Skip to main content](#)

<code>FILTER_VALIDATE_REGEXP</code>	Checks for a valid regular expression value
<code>FILTER_VALIDATE_URL</code>	Checks for a valid URL string

filter_var() function

The `filter_var()` function is used to validate and sanitize the data. It works by filtering a variable with a specified filter. To do this, you must define the variable you want the function to check, whether you want to validate or sanitize and the type of check to use.

The task below demonstrates how to use the `filter_var()` function to validate an email address using the `FILTER_VALIDATE_EMAIL` filter.



☒ `FILTER_VALIDATE_EMAIL`

Non-Assessed

[Skip to main content](#)

The code below validates an email address using the FILTER_VALIDATE_EMAIL filter.

```
<?php

// PHP program to validate email

// Declare variable and initialize it to email
$email = "xxx@openpolytechnic.ac.nz";

// Use filter function to validate email
if (filter_var($email, FILTER_VALIDATE_EMAIL)) {
    echo "Valid Email";
}
else {
    echo "Invalid Email";
}

?>
```

Test the above code with an incorrect email id. What happens?

☐ I have tested the code

Submit



Skip to main content

— — — — —

✓ FILTER_VALIDATE_IP

Non-Assessed

Write a PHP program using FILTER_VALIDATE_IP that validates an IP address.

☐ I have completed the task

Submit



Sanitize

You can also use sanitize filters to remove any unnecessary characters from the data to ensure that no undesired characters can affect your data.

You can use the `filter_var()` function to sanitise a string, which will remove all the HTML tags from a string. You'd use the code below to do this:

```
filter_var($variable, FILTER_SANITIZE_STRING);
```

The table below shows the sanitize filter constants that are available to help sanitise data.

Filter	Description
FILTER_SANITIZE_EMAIL	Removes all illegal characters from an email address
FILTER_SANITIZE_ENCODED	Removes/encodes special characters
FILTER_SANITIZE_MAGIC_QUOTES	Applies addslashes() function
FILTER_SANITIZE_NUMBER_FLOAT	Removes all characters except digits, +, - and optionally: . , e E

[Skip to main content](#)

<code>FILTER_SANITIZE_NUMBER_INT</code>	Removes all characters except digits, + and -
<code>FILTER_SANITIZE_SPECIAL_CHARS</code>	Removes special characters
<code>FILTER_SANITIZE_FULL_SPECIAL_CHARS</code>	Encoding quotes can be disabled by using <code>FILTER_FLAG_NO_ENCODE_QUOTES</code>
<code>FILTER_SANITIZE_STRING</code>	Removes tags/special characters from a string
<code>FILTER_SANITIZE_STRIPPED</code>	Alias of <code>FILTER_SANITIZE_STRING</code>
<code>FILTER_SANITIZE_URL</code>	Removes all illegal characters from a URL

Other filter constants, apart from sanitize or validate, are:

`FILTER_UNSAFE_RAW` : do nothing, optionally strip/encode special characters

`FILTER_CALLBACK` : call a user-defined function to filter data



☒ `FILTER_SANITIZE_EMAIL`

Non-Assessed

[Skip to main content](#)

In this activity, add the `FILTER_SANITIZE_EMAIL` constants to the code below to ensure the email address you receive is valid.

The `FILTER_SANITIZE_EMAIL` constant you create must:

- have three variables that hold both valid and invalid email addresses
- demonstrate a sanitised email id.

```
<?php
// PHP program to validate email

// Declare variable and initialize it to email
$email = "xxx@openpolytechnic.ac.nz";

// Use filter function to validate email
if (filter_var($email, FILTER_VALIDATE_EMAIL)) {
    echo "Valid Email";
}
else {
    echo "Invalid Email";
}

?>
```

☐ I have completed this task

Submit



Thoughts on this page?

